Case 02 · מודל איום: שלושת השורדים

מסמך משלים בין שלב ה-POC לאפיון. מטרתו: לפני שמפרטים פיצ'רים, להבין מה כל מערכת מגינה עליו, מי עלול לתקוף אותה, ואיפה. ההגנות שיוצעו כאן יהפכו לדרישות באפיון.

מה זה מודל איום, ואיך קוראים את המסמך

מודל איום עונה על ארבע שאלות: מה אנחנו מגינים עליו (נכסים), מי עלול לפגוע בזה ולמה (תוקפים), איפה הוא יכול להיכנס (גבולות אמון ומשטחי תקיפה), ומה עוצר אותו ומה נשאר פתוח (הגנות וסיכון שארית).

גבול אמון הוא כל מקום שבו מידע עובר מגורם אחד לגורם אחר שלא סומכים עליו באותה מידה. למשל, הרגע שבו קובץ מאתר של משרד אוצר נכנס למערכת שלנו. כמעט כל תקיפה מתרחשת על גבול כזה.

כדי לא לשכוח אף כיוון, האיומים ממוינים לפי STRIDE, שש קטגוריות שפיתחו במיקרוסופט:

- **S, Spoofing (התחזות):** מישהו מעמיד פנים שהוא מישהו אחר.
- **T, Tampering (שיבוש):** מישהו משנה נתונים או קוד בלי רשות.
- **R, Repudiation (הכחשה):** מישהו עשה משהו ואי אפשר להוכיח שזה הוא.
- **I, Information Disclosure (דליפת מידע):** מידע מגיע למי שלא אמור לראות אותו.
- **D, Denial of Service (מניעת שירות):** מישהו גורם למערכת להפסיק לעבוד.
- **E, Elevation of Privilege (הסלמת הרשאות):** מישהו מקבל יכולת שלא הייתה אמורה להיות לו.

לכל איום: מי התוקף, מה הוא עושה, מה הנזק, מה ההגנה, ומה נשאר פתוח גם אחרי ההגנה. "מה נשאר פתוח" הוא החלק הכי חשוב: מודל איום שטוען שהכול סגור הוא מודל איום לא כן.

כלל אחידות: לכל אחד משלושת השורדים שישה איומים, אחד לכל קטגוריה, באותה רמת פירוט.

1. Maturity Wall Simulator

מה מגינים עליו

- **נכונות התחזיות:** מספר שגוי על חוב של מדינה, שמתפרסם בשם הכלי, הוא הנזק הגדול ביותר.
- **שרשרת המקור:** היכולת להראות מאיזה קובץ רשמי, ובאיזו גרסה, יצא כל מספר.
- **האמון בכלי:** אם פעם אחת יתברר שתחזית זויפה, אף אחד לא יצטט אותו שוב.

מי עלול לתקוף

- **ספקולנט:** מרוויח מבהלה בשוק האג"ח, ולכן ירצה תחזית מפחידה שתיראה רשמית.
- **גורם פוליטי:** ירצה להראות שהתקציב של היריב "מוביל לקריסה", או שהתקציב שלו "מציל".
- **טרול או מפיץ דיסאינפורמציה:** ירצה צילום מסך מזויף עם הלוגו של הכלי.
- **תוקף רשת מקרי:** ינסה להפיל או להשחית את האתר בלי מטרה כלכלית.

גבולות אמון

שלושה מעברים: (1) מקור רשמי ← מתאם הטעינה, (2) מנוע ← פלט שמוצג למשתמש, (3) פלט ← העולם (צילומי מסך, ציטוטים).

האיומים

- **S, התחזות למקור:** תוקף מגיש קובץ שנראה כמו פרסום של משרד החוב (למשל דרך מראה מזויפת או DNS מורעל). נזק: כל התחזית בנויה על רשימת אג"ח לא אמיתית. הגנה: טעינה רק מכתובות HTTPS מוגדרות מראש, בדיקת תעודה, ובדיקת שלמות מול החוב שהמדינה מדווחת. נשאר פתוח: אם המקור הרשמי עצמו טועה, אנחנו נטעה איתו.
- **T, שיבוש בטעינה:** באג או שינוי פורמט אצל משרד החוב גורם למתאם לקרוא עמודה לא נכונה (למשל קופון במקום סכום). נזק: תחזית שגויה שנראית סבירה. הגנה: בדיקות טווח לכל שדה, השוואה לטעינה הקודמת, ועצירה אוטומטית כשהפער חריג. נשאר פתוח: שינוי קטן ועקבי יכול לעבור את כל הבדיקות.
- **R, הכחשת מקור:** מישהו מצטט "לפי הכלי, החוב יגיע ל-160%", ואין דרך להוכיח באילו הנחות ונתונים זה חושב. נזק: ויכוח שהכלי לא יכול להכריע. הגנה: לכל פלט מוצמדים טביעת אצבע (hash) של קובץ הקלט, גרסת המנוע וכל ההנחות, וקישור קבוע שמשחזר בדיוק את אותה תוצאה. נשאר פתוח: אי אפשר למנוע ציטוט חלקי שמשמיט את ההנחות.
- **I, שימוש לרעה בתוצאה:** תרחיש קיצוני מוצג כנבואה ("הכלי צופה קריסה של צרפת"). נזק: תרומה לבהלה שהכלי בא להבין, לא ליצור. הגנה: כל גרף נושא את ההנחות עליו (לא רק בהערת שוליים), אין ציונים או דירוגים למדינות, ותרחישים קיצוניים מסומנים ככאלה. נשאר פתוח: אין שליטה על מה שאנשים כותבים ברשתות.
- **D, הפלת השירות:** עומס על ה-API ברגע של לחץ בשוק, בדיוק כשכולם רוצים לבדוק. נזק: הכלי לא זמין כשהוא הכי נחוץ. הגנה: המנוע קל ויכול לרוץ גם בדפדפן של המשתמש, כך שהשרת מגיש בעיקר קבצים סטטיים. נשאר פתוח: עדכון הנתונים עצמו תלוי בשרת.
- **E, שינוי ברירות מחדל:** מי שמקבל גישת עריכה לתרחישי ברירת המחדל משנה אותם בשקט (למשל צמיחה נמוכה יותר) כדי שהתחזית הראשונה שכולם רואים תהיה מפחידה יותר. נזק: הטיה שקטה של כל המשתמשים. הגנה: ברירות המחדל נשמרות בקוד עם היסטוריית שינויים, וכל שינוי מוצג ביומן ציבורי. נשאר פתוח: גם ברירת מחדל "הוגנת" היא בחירה.

השורה התחתונה

האיום המרכזי כאן אינו פריצה, אלא אמינות: כלי שמספרים שלו מצוטטים חייב להוכיח מאיפה כל מספר הגיע. מה שעובר לאפיון: שרשרת מקור (provenance) מלאה לכל פלט, ובדיקות שלמות בכל טעינה.

2. Fire-Sale Cascade Simulator

מה מגינים עליו

- **נכונות המודל:** סימולציה שמתנהגת אחרת ממה שהיא טוענת היא גרועה מאין סימולציה.
- **נתוני הקלט, אם יהיו אמיתיים:** כרגע הכלי עובד על התפלגויות. אבל ברגע שמישהו יטען אליו מאזנים אמיתיים, הוא הופך למאגר של מידע רגיש מאוד.
- **האמון בתוצאה:** ההבדל בין "תרחיש לימודי" לבין "תחזית".

מי עלול לתקוף

- **ספקולנט:** ירצה "להוכיח" שגוף מסוים קורס, כדי להרוויח ממכירה בחסר.
- **מתחרה של גוף פיננסי:** ירצה לפרסם סימולציה שמציגה את המתחרה כחלש.
- **משתמש תמים:** יטען נתונים אמיתיים של המוסד שלו לכלי ציבורי, בלי להבין את הסיכון.
- תוקף רשת מקרי.

גבולות אמון

שלושה מעברים: (1) משתמש ← הגדרת עולם (פרמטרים או נתונים), (2) מנוע ← תוצאה, (3) תוצאה ← העולם.

האיומים

- **S, התחזות לכיול:** מישהו מפרסם "שחזור רשמי של משבר 2022 לפי הכלי" עם פרמטרים שבחר בעצמו. נזק: תוצאה מוטה שנראית כמו תוצר של הכלי. הגנה: עולמות מכוילים נשמרים כקבצים חתומים עם מזהה, והכלי מציג בבירור כשעולם אינו מתוך הספרייה הרשמית. נשאר פתוח: אין דרך למנוע ממישהו לטעון שהשתמש בכלי.
- **T, הנדסת תוצאה:** בחירה מכוונת של פרמטרים (עומק שוק נמוך, ספי מנוף צרים) כדי לייצר ספירלה מפחידה. ה-POC הראה שזה קל במיוחד, כי התוצאה קופצת בטווח צר. נזק: "הוכחה" מדומה לקריסה. הגנה: כל תוצאה מוצגת יחד עם בדיקת רגישות שמראה כמה היא תלויה בכל פרמטר, וברירת המחדל היא טווח ולא מספר. נשאר פתוח: משתמש שמצלם רק את הגרף המפחיד.
- **R, תוצאה בלי היסטוריה:** אי אפשר לשחזר איך הגיעו לתוצאה מסוימת. הגנה: seed קבוע, וכל הרצה מקבלת קישור שמשחזר אותה במדויק (פרמטרים, seed, גרסה). נשאר פתוח: שום דבר מהותי, זו בעיה שפותרים מלא.
- **I, דליפת מאזנים אמיתיים:** משתמש טוען מאזנים אמיתיים, והם נשמרים בשרת, ביומן או בקישור לשיתוף. נזק: חשיפה של מידע עסקי רגיש ביותר. הגנה: כל הסימולציה רצה בדפדפן, שום נתון לא נשלח לשרת, וקישורי שיתוף מכילים רק פרמטרים של התפלגויות ולא נתוני מוסדות. נשאר פתוח: מה שמשתמש עושה עם המחשב שלו.
- **D, מיצוי משאבים:** סריקה ענקית (מיליוני עולמות) תוקעת את הדפדפן. נזק: נמוך, פוגע רק במשתמש עצמו. הגנה: תקרה על גודל סריקה, והרצה ב-Web Worker כדי שהדף לא יקפא. נשאר פתוח: נמוך.
- **E, הפיכת כלי לימוד לכלי החלטה:** גוף מסוים מתחיל להשתמש בתוצאות כבסיס להחלטות השקעה או פיקוח. נזק: החלטות אמיתיות על בסיס מודל לא מכויל. הגנה: הצהרה בולטת שהכלי מיועד לחקירה, ולא כתחליף למבחני קיצון רשמיים. נשאר פתוח: זו הסלמה של סמכות, לא של הרשאה טכנית, ואין לה פתרון טכני.

השורה התחתונה

האיום המרכזי כאן הוא תוצאה מוטה שנראית אמינה, וה-POC הראה למה: התשובה קופצת בטווח צר של פרמטר אחד. ויש תפנית: ברגע שהכלי יקבל נתונים אמיתיים, הוא יהפוך ממודל לימודי למטרה רגישה. מה שעובר לאפיון: בדיקת רגישות כחלק מכל תוצאה, וריצה מקומית בלבד.

3. Private Exposure Registry

מה מגינים עליו

- **סודיות הנתונים של כל משתתף:** זו כל ההבטחה של המערכת.
- **נכונות התוצאה המצרפית:** רגולטור שמחליט על בסיס סכום שגוי.
- **זהות המשתתפים:** עצם ההשתתפות של קרן מסוימת יכולה להיות מידע רגיש.

מי עלול לתקוף

- **שרת סקרן:** מפעיל של אחד השרתים שמנסה ללמוד מה קרן מסוימת מחזיקה.
- **שני שרתים בקנוניה:** חיבור החלקים שלהם כדי לשחזר.
- **משתתף מתחרה:** ירצה ללמוד את החשיפות של קרן אחרת דרך התוצאות.
- **משתתף שמסתיר:** ידווח חשיפה נמוכה מהאמת כדי להיראות בטוח יותר.

- **גורם חיצוני:** ינסה ליירט תקשורת או להפיל שרת.

גבולות אמון

ארבעה מעברים: (1) משתתף ← שרתים (החלקים), (2) שרת ← שרת (תיאום), (3) שרתים ← שער הפרסום, (4) תוצאה ← רגולטור.

האיומים

- **S, התקפת סיביל (קרן מזויפת):** הסף של 5 משתתפים לתא נשמע בטוח. אבל תוקף שרוצה לגלות את הנתון של קרן יחידה בענף נדיר רושם 4 קרנות מזויפות עם ערך אפס באותו תא. הסף עובר, התא נפתח, והתוקף מחסיר את האפסים שלו ומקבל את הנתון של הקרן האמיתית. נזק: שבירה מלאה של הסודיות. הגנה: רישום משתתפים רק דרך רגולטור, עם מפתח שמונפק לכל גוף מפוקח אמיתי, ורעש DP שמטשטש גם תא שנפתח. נשאר פתוח: אם הרגולטור עצמו רושם משתתפים מזויפים.
- **T, שרת שמשבש חלקים:** שרת זדוני משנה את החלק שלו, והתוצאה המצרפית משתנה בלי שאף אחד ירגיש. ב-POC הנחנו שרתים "ישרים אך סקרנים", ושם זה לא מטופל. נזק: רגולטור רואה תמונה שגויה. הגנה: מעבר לפרוטוקול עם קודי אימות (MACs, כמו ב-SPDZ), שמזהה כל שינוי בחלק. נשאר פתוח: עלות ביצועים משמעותית, שצריך למדוד.
- **R, משתתף שמכחיש:** משתתף טוען "לא דיווחתי את זה", או "דיווחתי אחרת". נזק: אין דרך לאכוף דיווח נכון או להוכיח מה נשלח. הגנה: כל משתתף חותם על התחייבות קריפטוגרפית (commitment) לערכים שלו לפני הפיצול. ההתחייבות לא חושפת כלום, אבל אפשר לפתוח אותה בביקורת. נשאר פתוח: התחייבות מוכיחה מה נשלח, לא שזה היה נכון.
- **I, התקפת הפרשים:** שאלה על "כל הענפים" ואחריה שאלה על "כל הענפים חוץ מאנרגיה", וההפרש מגלה את אנרגיה גם אם התא שלה לבד היה חסום. נזק: עקיפה של הסף דרך שאלות חוזרות. הגנה: קטלוג שאלות סגור (אין שאלות חופשיות), ותקציב פרטיות כולל (privacy budget) שנגמר אחרי מספר שאלות מוגדר. נשאר פתוח: גם קטלוג סגור צריך בדיקה שאין בו זוגות שאלות כאלה.
- **D, שרת אחד נופל:** בשיטה של 3 מתוך 3, כל החלקים נחוצים. שרת אחד שלא זמין עוצר הכול. נזק: אין תמונה מצרפית בדיוק ברגע של לחץ, כשהיא הכי נחוצה. הגנה: מעבר ל-Shamir secret sharing של 2 מתוך 3, שבו כל שני שרתים מספיקים. נשאר פתוח: המחיר הוא ששני שרתים בקנוניה כבר יכולים לשחזר. זו פשרה אמיתית בין זמינות לסודיות, וצריך להכריע עליה באפיון.
- **E, משתתף שמשקר:** הקריפטוגרפיה מגינה על סודיות, לא על אמת. קרן יכולה לדווח חשיפה נמוכה מהאמת, ואף אחד לא יראה. נזק: התמונה המצרפית נראית בטוחה יותר מהמציאות. הגנה חלקית: בדיקות טווח מוצפנות (range proofs) שמוכיחות שהערך סביר בלי לחשוף אותו, והצלבה עם דיווחים מבוקרים שכבר קיימים אצל הרגולטור. נשאר פתוח: זה הסיכון הגדול ביותר שנשאר, ואין לו פתרון קריפטוגרפי מלא.

השורה התחתונה

כאן מודל האיום משנה את התכנון יותר מבשני האחרים. ה-POC הוכיח סודיות מול שרתים סקרנים, אבל לא מול שרת זדוני, לא מול קרן מזויפת, ולא מול משתתף שמשקר. מה שעובר לאפיון: רישום דרך רגולטור, אימות חלקים, תקציב פרטיות, והכרעה בין 3 מתוך 3 לבין 2 מתוך 3.

מה למדנו מהשוואת שלושת המודלים

- **בשני הסימולטורים, האיום המרכזי הוא אמינות התוצאה:** מספר שגוי או מוטה שנראה רשמי.
- ב-Registry, האיום המרכזי הוא סודיות, ומעליו אמת הנתונים.
- **איום אחד חוזר בשלושתם:** מישהו שמצלם רק את החלק המפחיד. אין לו פתרון טכני, רק תכנון שבו ההנחות צמודות לתוצאה.
- כל "נשאר פתוח" ברשימות הוא שאלה שהאפיון יצטרך לענות עליה, או להודות שאין לו תשובה.